AI-Assisted Threat Detection & Response System

Log-based detection, correlation, and AI SOC assistant mapped to MITRE ATT&CK

Presenter: [Your Name]
Date: 2026-10-11
Context: Resource-constrained environments (Lusaka, Zambia)
Dataset: CICIDS2017 (Tuesday/Friday captures, 957K flows)

Problem Statement

Small IT teams in emerging regions face asymmetric threats: - Limited security staff, budget, and tooling - No dedicated SOC, no 24/7 monitoring - Commercial SIEM/EDR often unaffordable - ISP is the primary upstream defense for DDoS

Our approach: - ML-based network flow detection (free/open-source stack) - Alert correlation → incident timeline - MITRE ATT&CK mapping for shared language - AI-assisted analyst reports (offline KB mode) - Deployable on commodity hardware

System Overview

6 pipeline steps, all offline-capable, reproducible

Data: CICIDS2017 Subset

Capture File	Flows	Attack Types
Tuesday-WorkingHours.pcap	445,641	BENIGN, FTP-Patator, SSH-Patator
Friday-Afternoon-PortScan.pcap	286,095	BENIGN, PortScan
Friday-Afternoon-DDoS.pcap	225,709	BENIGN, DDoS

After cleaning: 957,445 rows, 80 features, 0 duplicates, 0 NaN/Inf
Classes: BENIGN (656,784), PortScan (158,804), DDoS (128,025), FTP-Patator (7,935), SSH-Patator (5,897)

Features used: 78 numeric flow features (protocol, durations, packet counts, byte counts, IAT stats, flags, window sizes…)
Excluded: Flow ID, IPs, Ports, Timestamp, Label, is_attack, **Destination Port** (leaks label)

Model: XGBoost Multi-class Classifier

Parameter	Value
Algorithm	XGBoost (tree_method=hist)
Objective	multi:softprob
Estimators	200
Max Depth	8
Learning Rate	0.1
Benign Train Cap	150,000 (downsampled)
Evaluation	Stratified 2-fold out-of-fold (all flows)

Why XGBoost? - Handles tabular flow data natively - Fast training/inference on CPU - Built-in handling of class imbalance (via downsampling) - Feature importance for interpretability - No GPU required

Results: With vs Without Destination Port

Metric	Without Port (78 feat)	With Port (79 feat)	Δ
Precision	0.99987	0.99989	+0.002%
Recall	0.99988	0.99991	+0.003%
F1	0.99987	0.99990	+0.002%
FPR	6.09×10^{-5}	5.18×10^{-5}	-15%
TP / FP / FN / TN	300,625 / 40 / 36 / 656,744	300,634 / 34 / 27 / 656,750	—

Key insight: Destination Port leaks attack type in CICIDS2017 (21→FTP, 22→SSH, 80→DDoS).
Our production model **excludes it** — the 0.99987 F1 is honest for this dataset.

Hard Evaluation: Beyond Random Split

A) Chronological Split (Train Early, Test Late)

Metric	Value
Precision	0.9995
Recall	0.9970
F1	0.9982
FPR	1.08×10^{-4}

Per-attack recall (all **also in training**): - DDoS: 0.9987 | PortScan: 0.9971 | SSH-Patator: 0.9840

B) Leave-One-Attack-Out (Zero-shot on Unseen Attack)

Held-out Attack	Unseen Recall	Benign FPR
DDoS	**0.4496**	4.1×10^{-5}
FTP-Patator	0.0745	6.1×10^{-5}
PortScan	0.0004	4.6×10^{-5}
SSH-Patator	0.0027	6.6×10^{-5}

C) Cross-Capture (Train on N-1 Days, Test on Held-out Day)

Held-out Capture	Attack	Recall	Flag
Friday-DDoS	DDoS	0.0025	NOT TESTED
Friday-PortScan	PortScan	0.0004	NOT TESTED
Tuesday	FTP-Patator	0.0741	NOT TESTED
Tuesday	SSH-Patator	0.0029	NOT TESTED

Conclusion: Supervised model excels on known attacks, fails on novel/unseen types.
Future work: Add anomaly detection layer for zero-day coverage.

Alert Correlation & MITRE ATT&CK Mapping

Alert thresholds: min confidence 0.90, alert gap 30min, incident gap 60min, min flows 5

Attack	MITRE Technique	Tactic	Severity
PortScan	**T1595** Active Scanning (T1595.001 Scanning IP Blocks)	Reconnaissance	Medium
DDoS	**T1498** Network Denial of Service (T1498.001 Direct Network Flood)	Impact	High
FTP-Patator	**T1110.001** Brute Force: Password Guessing	Credential Access	High
SSH-Patator	**T1110.001** Brute Force: Password Guessing	Credential Access	High

7 alerts → 5 incidents:

ID	Severity	Source	Summary
INC-001	HIGH	172.16.0.1	FTP-Patator (T1110.001)
INC-002	HIGH	172.16.0.1	SSH-Patator (T1110.001)
INC-003	**CRITICAL**	172.16.0.1	**PortScan (T1595) → DDoS (T1498)**
INC-004	HIGH	192.168.10.9	DDoS (T1498)
INC-005	HIGH	192.168.10.5	DDoS (T1498)

INC-003 shows realistic progression: Reconnaissance → Impact (multi-tactic = CRITICAL)

AI SOC Assistant (Offline Knowledge-Base Mode)

Two modes: LLM (Anthropic Claude) / Offline KB (demo-safe, no API key)

Report sections for each incident: 1. Summary (what, when, tactics) 2. Timeline (per-alert with flow counts) 3. ATT&CK mapping (technique IDs + meaning) 4. Likely attacker goal 5. Immediate actions (Lusaka-context: free tools, ISP contact) 6. Longer-term fixes (fail2ban, MFA, CDN, network segmentation) 7. Caveats (ML detection ≠ compromise; NAT/shared IPs)

Example (INC-003 CRITICAL):

> "Source 172.16.0.1 showed 3 detected activity bursts (286,793 flows) covering Reconnaissance → Impact. Multiple stages from one source suggest deliberate, staged attack." - Immediate: Block scanner at firewall, confirm service impact, contact ISP for flood - Long-term: Port-scan detection (Suricata), CDN/DDoS protection, DoS runbook with ISP contacts

Limitations & Future Work

Current Limitations

Limitation	Impact	Mitigation
Supervised only — no zero-day detection	LOAO recall 0.04–45%	Add unsupervised anomaly layer (Isolation Forest, AE)
CICIDS2017 synthetic — not production traffic	Lab scores ≠ real-world	Validate on live Zeek/Suricata flows
Flow-level only — no payload/L7	Misses app-layer exploits	Integrate Zeek logs, TLS JA3 fingerprints
Single source IP correlation	Misses distributed/coordinated attacks	Graph-based correlation, multi-source fusion
Binary benign cap — 150K train limit	May under-represent benign diversity	Stratified sampling, class-weighted loss
No LLM eval — KB mode only	Can't measure hallucination rate	Run with API key when available

Future Work

1. **Anomaly detection layer** for unseen attack types
2. **Live packet capture** integration (Zeek, Suricata)
3. **Distributed correlation** across sensors
4. **LLM-assisted triage** with RAG on local KB
5. **Automated response playbooks** (block, rate-limit, alert)
6. **Edge deployment** on Raspberry Pi / Jetson for Lusaka clinics/schools

Conclusion

Delivered: End-to-end threat detection pipeline - Data cleaning → ML detection → Alert correlation → ATT&CK mapping → AI reports → Demo page - Honest evaluation: chronological, leave-one-attack-out, cross-capture - MITRE ATT&CK mappings aligned with attack.mitre.org (T1595, T1498, T1110.001) - Offline-capable, free/open-source stack, Lusaka-contextualized

Key results: - Baseline F1 0.9999 on known attacks (port excluded) - Hard eval reveals generalization gap (LOAO 0.04–45%) - Clear attack progression detected: PortScan → DDoS (INC-003 CRITICAL) - 5 analyst-ready reports with immediate/long-term actions

Ready for: Demo, pilot deployment, extension with anomaly detection

Repository: All code, data, models, outputs in this project

Run: `python step1_load_clean.py ... && python step2_baseline.py ... && python step3_alerts.py ... && python step4_assistant.py ... && python step5_hard_eval.py ... && python step6_demo_page.py`

Thank You / Questions

Backup slides: Detailed metrics, confusion matrices, demo script

Likely questions prepared: - Why XGBoost over Snort/Suricata? - Lusaka context: budget, ISP, ZM-CIRT - NAT/shared IP attribution caveats - LLM reliability / hallucination risk - Deployment architecture (edge vs cloud) - Unseen attack generalization - Scores: baseline vs honest evaluation

Contact: [Your details]